Security Awareness and Training Policy - Summary

Purpose

This policy promotes a culture of security and raises the security awareness of employees, contractors and other stakeholders. It defines how people are trained on information security best practices, policies and procedures, including the risks that come with using information technology, the security consequences of their actions, how to defend against malicious threats and how to react to security events and incidents.

Scope

The policy applies to every user of the organization's information systems: full-time and part-time employees, contractors and third parties working on the organization's behalf whether paid directly or through another employer, and employees of partners and clients who access the organization's non-public systems.

Core Requirements

The organization must run a formal security awareness and training program for its whole workforce.

Training content must combine general security awareness with the organization's own security policies and procedures, so people learn both the threats and the house rules for dealing with them.

Roles that carry higher risk, for example roles with privileged system access or frequent exposure to payments and sensitive data, must be identified and given additional training aimed at the specific risks of those roles.

Acceptable use rules must be developed and communicated to all stakeholders, so that everyone knows what responsible use of systems looks like before they are held to it.

People must be assessed on their security knowledge and on how they apply it, for example through computer-based tests and simulated phishing exercises.

Training must ensure every person can actually carry out the security duties their role assigns them, not just recognize threats in the abstract.

The Program in Practice

Awareness and training begin at onboarding, where new joiners complete the course and sign a declaration that they understand the requirements and intend to follow them. Training then continues on a recurring schedule, with assessments and simulations used to measure whether the message is landing and where refreshers are needed.

Noncompliance

Violations are treated like other allegations of wrongdoing and are adjudicated through established procedures. Sanctions can include disciplinary action, termination of employment and legal action under applicable laws and contracts.